MÒDUL 06 · SEGURETAT INFORMÀTICA — RA4 · NF5-AA1

Enginyeria social i phishing



La línia de defensa més feble no és la tecnologia: som nosaltres

CFGM Sistemes Microinformàtics i Xarxes · 2n curs

Institut Puig Castellar
Joan Sánchez

EN AQUESTA SESSIÓ

Què aprendrem avui?



Tècniques d'enginyeria social

Phishing, vishing, smishing, pretexting, baiting: com enganyen a les persones per aconseguir informació o accés.



Correu no desitjat (spam)

Marc legal, tècniques de filtratge i protocols d'autenticació de correu (SPF, DKIM, DMARC).



Prevenció i mitigació

Formació, MFA, mínim privilegi i protocols de resposta davant un possible atac.

HO SABIES?

El factor humà, l'objectiu preferit dels atacants

Per què ataquen les persones

Les eines de protecció tecnològiques (firewalls, IDS/IPS, antivirus) són cada cop més robustes. Per això els ciberdelinqüents prefereixen atacar la línia de defensa més feble: l'usuari final.

Kevin Mitnick

Un dels hackers més famosos dels anys 90, expert en aconseguir accés mitjançant enginyeria social (incloent-hi la cerca d'informació a la brossa de les empreses). Va escriure "The Art of Deception", un clàssic sobre el tema.

SUPLANTACIÓ DIGITAL

Phishing, spear phishing i whaling

Tècnica	Característica
Phishing	Enviament massiu de correus que simulen provenir de fonts fiables (bancs, botigues, l'empresa mateixa), per capturar contrasenyes o dades bancàries.
Spear phishing	Variant personalitzada dirigida a una persona o departament concret, usant informació específica de la víctima per fer l'atac més convincent.
Whaling	Spear phishing dirigit a executius d'alta direcció (CEO, CFO), amb un impacte potencial elevadíssim.

ALTRES CANALS

Smishing, vishing i tècniques de contextualització



Smishing i vishing

Smishing: enginyeria social via SMS, amb enllaços maliciosos o peticions urgents. Vishing: enginyeria social telefònica, suplantant suport tècnic o entitats bancàries.



Pretexting i baiting

Pretexting: l'atacant crea un escenari fictici (ex: tècnic de TI urgent) per guanyar-se la confiança. Baiting: un esquer físic/digital atractiu (ex: USB infectat amb l'etiqueta "Nòmines_2026.xlsx").

Amb la IA, els atacants poden generar veus i videoconferències falses (deepfake) amb gran realisme, fent el vishing encara més creïble.

OBSERVACIÓ DIRECTA

Shoulder surfing i dumpster diving



Shoulder surfing

Observació directa de les tecles o pantalles quan la víctima escriu contrasenyes, PINs o codis d'accés.



Dumpster diving

Cerca d'informació confidencial (llistes d'usuaris, manuals, contrasenyes anotades) en paper no destruït adequadament.

EL COST REAL

Impacte en organitzacions i empreses

- Frau del CEO / del proveïdor: suplantant un directiu o interceptant factures, els atacants aconsegueixen que els empleats facin transferències fraudulentes.
- Infecció per ransomware: més del 80% dels atacs de ransomware s'inicien amb un correu de phishing.
- Exfiltració de dades i sancions legals (RGPD/LOPDGDD): el robatori d'informació comporta pèrdues econòmiques, danys reputacionals i sancions administratives.

UN VELL CONEGUT

Correu no desitjat (spam)

- El correu brossa (spam) provoca dos grans inconvenients: consum de recursos de xarxa (congestió) i saturació de bústies, que pot bloquejar correus legítims.



La LSSI-CE estableix que l'enviament de correu comercial sense consentiment previ del destinatari és una infracció greu. La majoria del spam, però, prové de fora de l'àmbit legal i no es pot perseguir.

DEFENSA TÈCNICA

Protocols d'autenticació de correu

Protocol	Funció
SPF	Especifica quins servidors estan autoritzats a enviar correu en nom d'un domini.
DKIM	Afegeix una signatura digital al correu, que permet verificar que no ha estat alterat en trànsit.
DMARC	Indica com han de tractar-se els correus que no compleixen SPF/DKIM (carpeta de spam o rebuig directe).

Configurar malament aquests protocols pel propi domini fa que ALTRES servidors marquin els nostres correus com a sospitosos.

FILTRATGE

Com es detecta el correu brossa



Llistes

Negres (dominis/IP coneguts com a spammers), blanques (confiança total) i grises (retard temporal per detectar servidors legítims que reintenten).



Filtres heurístics

Analitzen el contingut buscant patrons típics de spam (paraules clau, enllaços sospitosos); sumen punts fins a superar un llindar.



Filtratge bayesià

Aprenentatge automàtic que calcula la probabilitat de spam a partir de l'historial de correus classificats per l'usuari.

DEFENSA EN PROFUNDITAT

Estratègies de prevenció i mitigació

- Formació i conscienciació contínua: simulacres periòdics de phishing i formació en identificació d'indicadors de sospita.
- Autenticació multifactor (MFA/2FA): encara que el delinqüent aconsegueixi la contrasenya, necessitarà un segon factor.
- Principi del mínim privilegi: cada usuari només accedeix a la informació estrictament necessària per a la seva feina.
- Polítiques de seguretat i protocols de resposta: notificació immediata i desconnexió ràpida de sistemes compromesos.
- Filtres de correu i sistemes de detecció: bloquejar missatges sospitosos abans que arribin a l'usuari.

PER ACABAR

Idees clau d'avui



El factor humà

L'enginyeria social ataca la manipulació psicològica, no el codi: firewalls perfectes no protegeixen d'un clic imprudent.



SPF/DKIM/DMARC

Configurar correctament aquests protocols és essencial perquè els propis correus siguin considerats legítims.



MFA + formació

La combinació de mesures tècniques (MFA) i humanes (formació contínua) és la defensa més eficaç contra el phishing.

ARA ÉS EL TORN VOSTRE

El departament de comptabilitat rep un correu del "director general" demanant una transferència urgent a un nou proveïdor, amb to d'urgència i confidencialitat.

En parelles: identifiqueu quina tècnica d'enginyeria social és aquesta, quins 3 indicadors de sospita hauria de detectar l'empleat, i quin protocol intern (procediment de verificació) hauria d'existir a l'empresa per evitar-ho.

10 minuts en parelles + posada en comú

FONTS DEL MATERIAL

Webgrafia

NF5-AA1: Enginyeria Social, Fraus i Robatori d'Informació

Repositori "Materials" (GitHub, SMX-0226SI) · Carlos Alonso Martínez, Escola Pia de Mataró · Llicència CC-BY-SA-4.0

INCIBE — Fraude del CEO

incibe.es/empresas/blog/fraude-del-ceo-el-engano-que-puede-vaciar-la-cuenta-de-tu-pyme

ESET — Phishing

eset.com/es/caracteristicas/phishing/

PowerDMARC — All About SPF, DKIM, and DMARC

powerdmarc.com

Llicència CC BY-SA 4.0 · Adaptat de "Materials" (SMX-0226SI), Carlos Alonso Martínez, Escola Pia de Mataró